

Prince Sultan University

College of Computer & Information Sciences

Information Systems Department

IS499 – Senior Project

D2 – Work Plan and Budget

Mirsad (مرصاد)

A Runtime Security Firewall for AI Agents Against Prompt-Injection Attacks

Team member	Student ID	Department
Mohammed Yasser Alanssari	221110935	IS (CYS)
Bader Alshuraie	221110016	SE
Bader Abdullah Abbod Alyamini	221110197	IS (CYS)
Abdulmalik bin Saedan	221110958	IS (CYS)
Abdullah Naif Abdullah Al-Orabi	222110432	SE (AI & DS)

Supervisor Dr. Omaia Al-Omari

Semester & Academic Year Senior Project I & II – Academic Year 2026–2027

Submission Date _____

Supervisor's Signature _____

Approval Date _____

Table of Contents

Table of Contents i
1 Introduction 1
1.1 Purpose of this document 1
1.2 Sources and how the plan is kept current 1
1.3 Structure of the document 2
2 Work Breakdown Structure 3
2.1 Work packages 3
2.2 Responsibility summary 5
3 Schedule 6
3.1 Gantt chart 6
3.2 Milestones 6
3.3 Sprint plan 7
3.4 Dependencies and critical path 8
3.5 Progress against the baseline 8
4 Weekly Task Breakdown 10
4.1 Mapping the IS499 calendar to the team plan 10
4.2 Weekly routine 11
5 Budget 12
5.1 Original SPAP budget 12
5.2 Decisions that changed the budget 12
5.3 Revised budget 12
5.3.1 LLM API usage: 450 SAR 13
5.3.2 Cloud VM: 540 SAR 13
5.3.3 Google Play registration: 0 SAR 14
5.3.4 Domain and TLS: 45 SAR 14
5.3.5 Contingency: 150 SAR 14
5.4 Zero-cost fallback 14
5.5 Budget control 15
6 Risk Register 16

6.1 Method 16
6.2 Proposal risks and their status 16
6.3 Risks added during the build 18
7 Resource Plan 19
7.1 People 19
7.2 Hardware 19
7.3 Software 19
7.4 Accounts and external services 20
References 21

1 Introduction

1.1 Purpose of this document

This document is deliverable D2 (Work Plan and Budget) of the IS499 Senior Project **Mirsad** (مرصاد), a runtime security gateway that sits between large language model (LLM) agents and the tools they call. Mirsad checks every tool call against a declarative YAML policy, tracks where data came from (taint tracking), scans tool results for injected instructions in Arabic and English, asks a human to approve high-risk actions through an installable mobile web app, and records every decision in a tamper-evident audit log.

D2 explains how the five-member team divides, schedules, resources and funds this work across Senior Project I (Fall 2026) and Senior Project II (Spring 2027). It revises the plan and budget submitted with the Senior Project Agreement and Proposal (SPAP) and records the status of each project risk on 11 October 2026.

1.2 Sources and how the plan is kept current

The plan is kept as data rather than prose. Phases, work packages, owners, dates and milestones are defined once in `docs/pm/plan.yaml`. The Gantt chart is generated from that file by `scripts/make_pm_figures.py`, and the work breakdown, milestone and weekly tables in this document use the same data. Every price in Section 5 was read from the vendor's own page on 11 October 2026 and is cited. Every measured value in the risk register is read from `reports/results_summary.json` when the document is built, so the text cannot drift from the evidence.

The team works in two-week Scrum sprints [1], with a product backlog, a sprint review in the bi-weekly supervisor meeting and a retrospective at the end of each sprint. Security work (threat modelling, code review, static analysis, dependency scanning and security tests) is part of every sprint. The public interfaces between workstreams are fixed in an engineering contract (`docs/dev/BUILD_SPEC.md`) so that the five workstreams can proceed in parallel.

Table 1: Planning baseline

Item	Value
Duration	1 September 2026 to 20 May 2027, with a winter break from 25 December 2026 to 9 January 2027
Structure	7 phases, 26 work packages, 17 sprints, 7 milestones (M1–M7)
Team	5 students (2 Software Engineering, 3 Information Systems – Cybersecurity); supervisor Dr. Omaia Al-Omari
Budget	1,185 SAR revised (SPAP: 1,660 SAR), with a documented zero-cost fallback

Item	Value
Plan sources	`docs/pm/plan.yaml` (schedule and owners), `docs/research/budget-evidence.md` (prices)

1.3 Structure of the document

Section 2 breaks the work into work packages with owners and outputs. Section 3 gives the schedule, milestones, sprint plan and critical path. Section 4 maps the 15-week IS499 calendar and deliverables D1–D6 to the team plan. Section 5 presents the original and revised budgets with their price evidence and a zero-cost fallback. Section 6 is the risk register, and Section 7 lists the people, hardware, software and accounts the project needs.

2 Work Breakdown Structure

2.1 Work packages

The project is decomposed into seven phases (level 1) and 26 work packages (level 2). Table 2 lists each work package with its owner, planned dates and main output. Owners are abbreviated as BS (Bader Alshuraie), AO (Abdullah Naif Abdullah Al-Orabi), BY (Bader Abdullah Abbod Alyamini), MA (Mohammed Yasser Alanssari) and AB (Abdulmalik bin Saedan); ALL means the whole team. Project management (WBS 0) is a level-of-effort activity that runs for the whole project and is therefore not drawn in the Gantt chart.

A work package is complete when its output has been reviewed by a second team member, its automated tests pass, and its documentation under `docs/` is up to date.

Table 2: Work breakdown structure

WBS	Work package	Owner	Planned dates	Main output
0	**Project management**	AB	1 Sep 2026 – 20 May 2027	Sprint plans, risk register, budget log, progress reporting to the supervisor
1	**Investigation and requirements**		1 Sep – 25 Oct 2026	
T1.1	Literature review and related products	ALL	1 Sep – 30 Sep 2026	Literature review; research notes in `docs/research/`
T1.2	Threat model (STRIDE) and attack taxonomy	BY, AB	14 Sep – 8 Oct 2026	Threat model and data-flow diagrams; abstract attack categories
T1.3	Requirements analysis and SRS (D3)	ALL	21 Sep – 20 Oct 2026	D3 SRS; requirement baseline at M1
T1.4	Benchmark and dataset design	AB, AO	1 Oct – 25 Oct 2026	Mirsad-Bench scenario schema; dataset labelling guidelines
2	**Design**		18 Oct – 15 Nov 2026	
T2.1	Architecture and high/low-level design (D4)	BS	18 Oct – 12 Nov 2026	D4; engineering contract
T2.2	Policy language specification	BS	20 Oct – 10 Nov 2026	YAML policy schema version 1 (`docs/policy-language.md`)
T2.3	Database and audit-chain design	BY	25 Oct – 12 Nov 2026	Entity-relationship model; HMAC hash-chain design
T2.4	UI wireframes (dashboard and approver app)	MA	25 Oct – 15 Nov 2026	Wireframes for the dashboard and the approver PWA
3	**Prototype (Senior Project I)**		15 Nov – 24 Dec 2026	
T3.1	Gateway, MCP proxy and basic policies	BS	15 Nov – 15 Dec 2026	Gateway pipeline, MCP proxy, policy engine

WBS	Work package	Owner	Planned dates	Main output
T3.2	Audit log and storage	BY	15 Nov – 10 Dec 2026	Hash-chained audit log; database layer
T3.3	Dataset authoring (Arabic/English) starts	AO, ALL	15 Nov – 20 Dec 2026	First labelled batches, benign and attack-labelled
T3.4	Senior Project I report and prototype demo	ALL	10 Dec – 24 Dec 2026	Midterm report; prototype demonstration (M3)
4	**Implementation I**		10 Jan – 20 Feb 2027	
T4.1	Injection detector (rules and model) and training	AO	10 Jan – 20 Feb 2027	Detector package; trained model; metrics report
T4.2	Taint tracking engine	BY	10 Jan – 15 Feb 2027	Taint tracker and its four flow rules
T4.3	OpenAI-compatible proxy and SDK	BS	20 Jan – 20 Feb 2027	`/v1/chat/completions` proxy; Python SDK
5	**Implementation II**		1 Feb – 20 Mar 2027	
T5.1	Approver PWA and notifications	MA	1 Feb – 15 Mar 2027	Installable approver app; Web Push
T5.2	Administration dashboard (English/Arabic)	MA	1 Feb – 20 Mar 2027	Dashboard pages with right-to-left Arabic layout
T5.3	Demo workspace and LLM demo agent	AB	10 Feb – 15 Mar 2027	Simulated workspace of a fictional company; demonstration agent
T5.4	Approval workflow and administration API	BS, BY	15 Feb – 20 Mar 2027	Approval service; REST administration API
6	**Testing and evaluation**		10 Mar – 20 Apr 2027	
T6.1	Unit, integration and UI tests (D5)	ALL	10 Mar – 10 Apr 2027	Automated test suites; D5
T6.2	Mirsad-Bench runs (scripted and LLM agents)	AB	15 Mar – 15 Apr 2027	Benchmark reports
T6.3	Detector evaluation and error analysis	AO	15 Mar – 10 Apr 2027	Held-out results; error analysis
T6.4	Penetration test of the gateway	AB, BY, MA	25 Mar – 20 Apr 2027	Security test report
7	**Finalization**		10 Apr – 20 May 2027	
T7.1	User guide (D6) and deployment	MA, BS	10 Apr – 30 Apr 2027	D6; deployment files
T7.2	Final report, poster and slides	ALL	15 Apr – 10 May 2027	Final report, poster, slides
T7.3	Open-source release and final presentation	ALL	5 May – 20 May 2027	Public release; final presentation (M7)

2.2 Responsibility summary

Each technical workstream has one accountable owner. Table 3 shows the work packages each member owns alone and those they share; the six ALL packages (T1.1, T1.3, T3.4, T6.1, T7.2 and T7.3) involve every member.

Table 3: Work-package ownership by member

Member	Workstream	Sole owner	Shared
Bader Alshuraie (BS)	Gateway core, adapters, policy engine	T2.1, T2.2, T3.1, T4.3	T5.4, T7.1
Abdullah Naif Abdullah Al-Orabi (AO)	Detector and dataset	T4.1, T6.3	T1.4, T3.3 (lead)
Bader Abdullah Abbod Alyamini (BY)	Taint tracking and audit log	T2.3, T3.2, T4.2	T1.2, T5.4, T6.4
Mohammed Yasser Alanssari (MA)	Dashboard and approver PWA	T2.4, T5.1, T5.2	T6.4, T7.1
Abdulmalik bin Saedan (AB)	Project management, demo workspace and agent, benchmark, security testing	WBS 0, T5.3, T6.2	T1.2, T1.4, T6.4

3 Schedule

3.1 Gantt chart

Figure 1 shows the schedule generated from `docs/pm/plan.yaml`. Phases overlap on purpose: design starts while requirements are being finalised, and the two implementation phases run in parallel because they belong to different owners. The winter break (25 December 2026 to 9 January 2027) is shaded and contains no planned work.

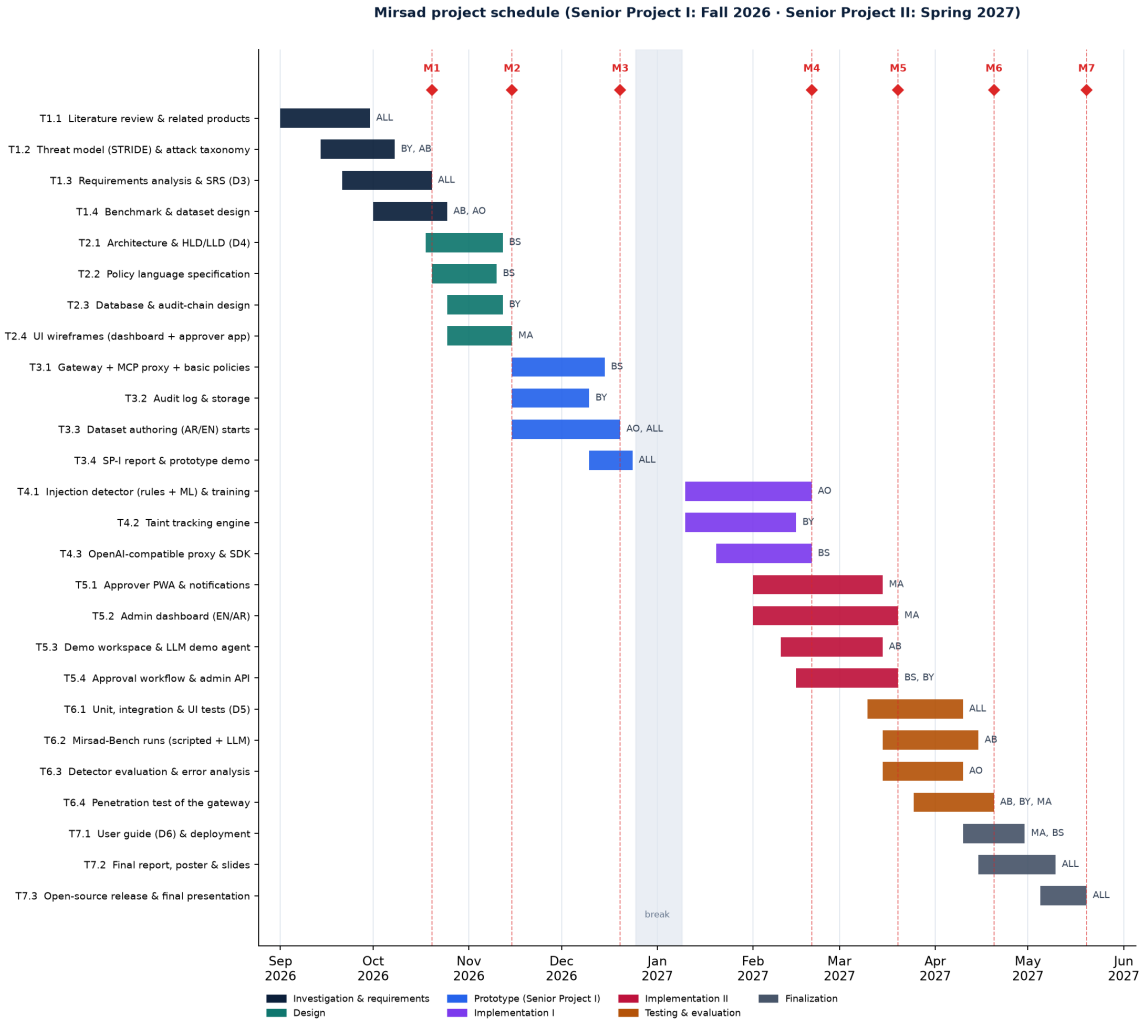


Figure 1: Mirsad schedule generated from docs/pm/plan.yaml: 26 work packages in seven phases with their owners, and milestones M1–M7 shown as red diamonds

3.2 Milestones

Each milestone closes a phase and is tied to proposal objectives O1–O6. Table 4 also states the evidence the team will present to the supervisor to show that the milestone has been reached.

Table 4: Milestones and completion evidence

ID	Milestone	Target date	Objectives	Completion evidence
M1	Proposal approved; threat model and SRS agreed	20 Oct 2026	O1–O6 scoped	Approved SPAP; D3 accepted as the requirement baseline
M2	Architecture and policy language approved	15 Nov 2026	O1, O2	D4 reviewed; policy schema version 1 frozen
M3	Prototype intercepts MCP traffic with policies	20 Dec 2026	O1, O2	Live demonstration of MCP calls allowed, denied and audited according to a policy
M4	Taint tracking and detector integrated	20 Feb 2027	O3, O4	Taint rules and detector active in the gateway; detector metrics on held-out Arabic and English test sets
M5	Approval app, dashboard and audit complete	20 Mar 2027	O5	Approval round trip from a phone; audit verification and decision replay in the dashboard
M6	Benchmark and security testing complete	20 Apr 2027	O6	Mirsad-Bench reports, including attack success rate; security test report
M7	Final submission and presentation	20 May 2027	All	Final report, poster, slides and public release

3.3 Sprint plan

The 17 sprints in Table 5 turn the work packages into two-week goals. Sprints S1–S8 belong to Senior Project I and S9–S17 to Senior Project II; the last sprint is extended to the final presentation date.

Table 5: Sprint plan summary

Sprint	Dates	Sprint goal	Milestone
S1	1–14 Sep 2026	Literature review, product analysis, team setup, repository and CI skeleton	
S2	15–28 Sep 2026	Threat model, attack taxonomy, stakeholder personas	
S3	29 Sep–12 Oct 2026	SRS: functional and non-functional requirements, use cases	
S4	13–26 Oct 2026	Benchmark and dataset design; requirement baseline agreed	M1
S5	27 Oct–9 Nov 2026	Architecture, engineering contract, policy language, database design	
S6	10–23 Nov 2026	UI wireframes; gateway core and MCP proxy	M2
S7	24 Nov–7 Dec 2026	Policy engine, rate limiter, audit log and storage	
S8	8–21 Dec 2026	Prototype demonstration and Senior Project I report	M3
S9	10–23 Jan 2027	Taint tracking; detector normalisation and rules	
S10	24 Jan–6 Feb 2027	Detector model and dataset pipeline; OpenAI-compatible proxy and SDK	

Sprint	Dates	Sprint goal	Milestone
S11	7–20 Feb 2027	Detector training and evaluation; integration	M4
S12	21 Feb–6 Mar 2027	Approval workflow, approver PWA, notifications	
S13	7–20 Mar 2027	Dashboard, demo workspace and demo agent	M5
S14	21 Mar–3 Apr 2027	Test specification and automated tests (D5); benchmark runs	
S15	4–17 Apr 2027	Security testing; latency and evaluation report	
S16	18 Apr–1 May 2027	User guide (D6), deployment, documentation	M6
S17	2–20 May 2027	Final report, poster, presentation and open-source release	M7

3.4 Dependencies and critical path

Most work packages depend only on the engineering contract, so they can run in parallel. The chain that sets the end date runs through the data:

1. T1.3 (requirements) and T1.4 (dataset design) fix what the detector must recognise and how test data is kept apart from training data.
2. T3.3 (dataset authoring) must deliver attack-labelled batches written by the team before T4.1 can train a model.
3. T4.1 (detector) and T5.3 (demo workspace) must both be ready before T6.2 (benchmark runs) and T6.3 (detector evaluation) can produce the results that M6 requires.
4. T6.2 and T6.3 feed T7.2 (final report).

Any delay in the team-authored data moves M4 and M6. Section 6 records this as risk R2, which has already occurred.

3.5 Progress against the baseline

The baseline dates above are kept for reporting to the supervisor. At the time of the recorded evidence run (2026-10-14T07:58:56+00:00; Appendix B.1 of the final report), the repository already contains working implementations of the components planned for phases 3 to 5: the gateway and its adapters, the policy engine, taint tracking, the detector's normalisation, rules and training pipeline, the audit log, the approval service, the dashboard, the approver PWA, the demo workspace and Mirsad-Bench. The automated suites hold 1,281 Python tests (0 failing) and 194 web tests (0 failing), with 94.4% statement coverage of the core package.

The work that remains on the critical path is the team-authored labelled data (T3.3), training and evaluating the detector on it (T4.1, T6.3), running the benchmark's attack episodes on the team's attack files (T6.2), the penetration test (T6.4), verifying the

Docker deployment (T7.1) and the documentation deliverables. Implemented work packages move to review and hardening in their scheduled sprints.

4 Weekly Task Breakdown

4.1 Mapping the IS499 calendar to the team plan

The IS499 syllabus places deliverables D1–D6 on a single 15-week calendar, while the Mirsad plan spreads the same work over two semesters. Table 6 links each syllabus week to the work packages and sprints that produce its deliverable, so the supervisor can check any week of the syllabus against the team plan. Submission dates for each syllabus week are set by the course coordinator; the table fixes only which work is due at that point.

Table 6: IS499 weekly breakdown mapped to the team plan

Week	IS499 activity or deliverable	Work packages	Sprints	Lead	Output
1	D1 Project proposal	T1.1, WBS 0	S1	ALL	SPAP form; repository and CI skeleton
2	D2 Work plan and budget (drafting)	T1.1, WBS 0	S1–S2	AB	Work breakdown, Gantt chart, price evidence
3	D2 submission	T1.2, WBS 0	S2	AB	D2 (this document) with risk register
4	D3 SRS (elicitation and analysis)	T1.2, T1.3	S3	ALL	Threat model; requirement and use-case drafts
5	D3 submission	T1.3, T1.4	S3–S4	ALL	D3 SRS; requirement baseline (M1)
6	D4 design (architecture)	T2.1, T2.2	S5	BS	Architecture, engineering contract, policy schema
7	D4 submission	T2.3, T2.4	S5–S6	BY, MA	D4 with database, audit-chain and UI design (M2)
8	Midterm report (D1–D4)	T3.4	S8	ALL	Senior Project I report and prototype demonstration (M3)
9	Implementation iteration 1	T3.1, T3.2, T4.2	S7, S9	BS, BY	Policy engine, audit log, taint tracker
10	Implementation iteration 1 review	T3.3, T4.1, T4.3	S10–S11	AO, BS	Detector model and metrics; OpenAI-compatible proxy and SDK (M4)
11	Implementation iteration 2	T5.1, T5.4	S12	MA, BS, BY	Approval workflow, approver PWA, notifications
12	Implementation iteration 2 review	T5.2, T5.3	S13	MA, AB	Dashboard; demo workspace and agent (M5)
13	D5 test cases and results; D6 user guide	T6.1–T6.4, T7.1	S14–S16	ALL	D5, D6, benchmark and security reports (M6)
14	Final report	T7.2	S17	ALL	Final report and poster
15	Final presentation	T7.3	S17	ALL	Presentation and open-source release (M7)

4.2 Weekly routine

Every sprint starts with planning from the product backlog and ends with a review in the supervisor meeting. The project manager updates the risk register and the budget log at the end of each sprint and reports any milestone at risk at the next supervisor meeting. Before each deliverable is submitted, the evidence script (`scripts/run_evidence.sh`) is run again, so the numbers quoted in a deliverable come from the code as submitted.

5 Budget

All amounts are in Saudi riyals (SAR). US-dollar prices are converted at the official peg of 3.75 SAR per USD [2]. Vendor prices exclude VAT and card or foreign-exchange fees unless the page says otherwise; the contingency line covers them.

5.1 Original SPAP budget

Table 7: Original budget in the SPAP

Line	Amount (SAR)
LLM API usage	750
Cloud virtual machine	600
Google Play developer registration	100
Domain name and TLS certificate	60
Contingency	150
Total	**1,660**

The SPAP gave these figures without price sources or a token model for the LLM line.

5.2 Decisions that changed the budget

Two design decisions made after the proposal change what the project must buy:

1. **Local models for development and most of the evaluation.** Ollama is an open-source runtime that serves open-weight models on the team's own machines with no usage fee [3], and it exposes an OpenAI-compatible API with tool calling [4]. Mirsad's OpenAI-style adapter therefore needs no second code path, and paid API calls are kept for one confirmatory run per cloud provider.
2. **A Progressive Web App (PWA) instead of store-distributed native approval apps.** Web Push works for web apps on Android and, since iOS and iPadOS 16.4, for web apps added to the Home Screen, without a developer-program membership [5]. This removes the Google Play line and avoids an Apple fee that the SPAP never counted.

5.3 Revised budget

Table 8: Original and revised budget (SAR)

Line	SPAP	Revised	Change
LLM API usage	750	450	Local models for development; one confirmatory run per provider
Cloud VM (2 vCPU, 4 GB, 6 months)	600	540	Priced from plans that can be

Line	SPAP	Revised	Change
			ordered today
Google Play registration	100	0	PWA instead of store apps
Domain and TLS	60	45	.com domain; free certificate
Contingency	150	150	About 14.5% of the 1,035 SAR subtotal
Total	**1,660**	**1,185**	**Saving 475 SAR (28.6%)**

5.3.1 LLM API usage: 450 SAR

The confirmatory run uses one mid-tier model from each of two providers: Claude Sonnet 5.5 at $2 input and $10 output per million tokens [6], [7] and OpenAI `gpt-6.1-sol` at the same list prices, with function calling supported [8], [9]. The planning assumption is about 2,000 benchmark episodes of about 6,000 tokens, or 12 million tokens per model per run. Agent episodes resend tool outputs and history on every turn, so the base case assumes 5,000 input and 1,000 output tokens per episode.

Table 9: LLM cost per full 2,000-episode run

Scenario	Claude Sonnet 5.5	gpt-6.1-sol
Base case: 10M input + 2M output tokens	$40 = 150 SAR	$40 = 150 SAR
Output-heavier: 8M input + 4M output tokens	$56 = 210 SAR	$56 = 210 SAR
Base case through a batch interface (50% discount)	$20 = 75 SAR	$20 = 75 SAR

One base-case run on both providers costs 300 SAR and the output-heavier case 420 SAR. The 450 SAR line ($120) covers the output-heavier case, which allows for reasoning tokens billed as output [8] and for the higher token counts of Anthropic's newer tokenizer [6]. Multi-turn episodes need each turn's result before the next, so batch pricing is treated as a possible saving rather than assumed. Anthropic credits are prepaid, non-refundable and expire one year after purchase [10], so credits are bought just before the run with automatic top-up switched off.

5.3.2 Cloud VM: 540 SAR

The VM runs only the gateway, the PWA backend and the audit database; the LLM does not run on it, so 2 vCPU and 4 GB are enough. Table 10 compares the options for six months.

Table 10: Cloud VM options, 2 vCPU and 4 GB for six months

Provider and plan	Per month	6 months	Note
DigitalOcean Basic Droplet, 80 GB SSD	$24.00	540.00 SAR	Orderable; includes IPv4

Provider and plan	Per month	6 months	Note
[11]			
AWS Lightsail, 80 GB SSD, IPv4 [12]	$24.00	540.00 SAR	Orderable
Hetzner CPX22 + IPv4 [13], [14]	$23.59	530.78 SAR	Orderable
Hetzner CX23 + IPv4 [13], [14]	$7.09	159.53 SAR	Listed as not available on 11 Oct 2026 [15]

Two independent providers agree on $24 per month, so the line is 6 × 90 = 540 SAR. If the cheaper Hetzner plan becomes orderable, the saving returns to contingency.

5.3.3 Google Play registration: 0 SAR

A Play listing would cost a one-time US$25 (93.75 SAR) [16], and new personal developer accounts must first run a closed test with at least 12 testers for 14 consecutive days [17]. An iOS app would add 99 USD (371.25 SAR) every year [18]. The PWA needs neither, and it can be installed from the browser on the day it is deployed.

5.3.4 Domain and TLS: 45 SAR

A .com name costs $11.08 (41.55 SAR) per year at Porkbun, with registration and renewal at the same price and ICANN fees included [19]; the line is rounded to 45 SAR. A stable name gives the PWA a fixed HTTPS origin, which installed web apps and push subscriptions depend on. Certificates from Let's Encrypt are free [20]. HTTPS cannot be dropped because service workers run only in secure contexts [21], and the deployment must renew certificates automatically because default certificate lifetimes shorten during the project year [22]. A .sa name is an option at 52.18 SAR in the first year from a licensed registrar [23], [24] if a team member who meets the eligibility rules registers it [25].

5.3.5 Contingency: 150 SAR

The contingency is kept at its SPAP value, about 14.5% of the 1,035 SAR subtotal. Prices changed sharply during 2026: Hetzner raised its CX23 price by a factor of 1.38 and its CPX22 price by 2.44 in June 2026 [13], and Google's paid Gemini prices are scheduled to double on 1 January 2027 [26]. The line also covers VAT, card and exchange fees, and API reruns if a benchmark run must be repeated.

5.4 Zero-cost fallback

If no funding is approved, Mirsad can still be built, evaluated and demonstrated at 0 SAR, with the limits stated in Table 11.

Table 11: Zero-cost fallback plan

Need	Zero-cost substitute	Limitation

Need	Zero-cost substitute	Limitation
LLM for development and the full benchmark	Ollama with open-weight models on team laptops or university lab machines [3], [4]	Weaker models than the cloud mid-tier; results must be labelled as local-model results
Cloud-model comparison	Gemini free tier on synthetic benchmark data only [26]	Free-tier content may be used by the provider; rate limits; otherwise report that no cloud comparison was run
Public gateway host	Azure student credit through the GitHub Student Developer Pack [27], [28]; Oracle Cloud Always Free Arm instance [29]; or a lab machine behind a free Cloudflare Tunnel [30]	Idle Oracle instances can be reclaimed, so deployment must be scripted; a tunnel depends on the machine staying on
Domain	Free one-year domains in the Student Developer Pack [27], or a Let's Encrypt certificate for the server's IP address [31]	IP-address certificates last about six days and need automated renewal
TLS	Let's Encrypt [20]	Renewal must be automated
Mobile approvals	PWA with standard Web Push [5]	iOS users must add the app to the Home Screen first
One-off live demo	Cloudflare Quick Tunnel [32]	Testing only; the hostname changes on every start and Server-Sent Events are not supported, which breaks the approval stream

If the budget is only partly funded, lines are cut in this order: the VM first (move to a student credit or the free tier), then the domain (use a pack domain), and finally the LLM line (a 1,000-episode confirmatory run, about 225 SAR).

5.5 Budget control

The project manager (AB) keeps a budget log of every purchase with its date, line, amount, receipt and the account it was charged to. A purchase is made only against an approved line, and no recurring subscription or automatic credit top-up is left switched on. Before any API credits are bought, the token count per episode is measured on the first 50 local episodes and the LLM line is re-costed with the formulas in Table 9.

6 Risk Register

6.1 Method

Each risk has one owner, who monitors it and carries out the mitigation. Likelihood (L) and impact (I) are rated High, Medium or Low as currently assessed. Status is one of: **Open** (may still occur), **Monitoring** (mitigations in place, measured regularly), **Occurred – mitigated** (the event happened and its effect has been contained) or **Occurred – open** (the event happened and mitigation is still in progress). The register is reviewed at the end of every sprint.

6.2 Proposal risks and their status

Table 12 carries forward the eight risks of the proposal (R1–R8) and records what happened during the build. Measured values are read from `reports/results_summary.json`.

Table 12: Risk register for the proposal risks

ID	Risk	Owner	L / I	Mitigation	Status and what happened
R1	The MCP specification and its official Python SDK change quickly and break the protocol adapters.	BS	H / M	Keep all protocol handling in the adapter package; code against the engineering contract; test adapters with real MCP clients over stdio and HTTP.	**Occurred – mitigated.** The SDK moved from major version 1 to version 2 during the build, with a new client API and a renamed server class, so version 1 examples no longer work. Only the adapter package was written against version 2; the policy, taint, detector and audit packages were unaffected. 78 adapter tests pass. Open action: `pyproject.toml` still accepts `mcp>=1.12`; the adapter owner's request to pin version 2 must be applied.
R2	Too little labelled Arabic and English injection data to train the detector and to run attack episodes.	AO, AB	H / H	Labelling guidelines; batch-wise train/test split; held-out test batches written by a different member; public datasets with licence notes.	**Occurred – open.** The attack-labelled examples and attack templates are written by the team, not by the AI assistant used during development, and are not yet available. The repository therefore holds only benign detector data and an empty attack folder, and the detector runs on its rules-only fallback. The team supplies the data following `docs/detector.md` and `bench/scenarios/attacks/README.md`. Detector F1 (English [pending], Arabic [pending]) is produced by `make detector` once the data is added. Attack success rate reduction ([pending]) is produced by the benchmark, which already executes attack episodes, once the attack files are added.

ID	Risk	Owner	L / I	Mitigation	Status and what happened
R3	False positives and approval requests disrupt legitimate work and cause alert fatigue.	AB	M / H	Benign-only benchmark episodes for every defence configuration; monitor mode for trialling policies; plain-language approval summaries.	**Monitoring.** On 48 scripted benign tasks in English and Arabic (68 calls) with full protection, the automatic false-positive rate is 0.0% and 17.6% of benign calls are escalated to a human. Utility is 100% when the approver accepts legitimate requests and 75% if every escalation is denied. The friction comes from the policy layer (17.6% alone) and the taint layer (8.8% alone), not from the detector (0.0%); part of it falls on tasks that do not need approval, so policy tuning continues.
R4	Mirsad adds more than the 200 ms median latency budget (NFR1).	BS	L / M	Asynchronous I/O; CPU-only linear detector; latency benchmark over 1,000 calls.	**Monitoring.** With the server in a separate process, the median added latency is 2.7 ms for sequential calls and 166 ms (p95 208 ms) with 50 concurrent sessions and 0 errors. Measured with the rules-only detector; to be repeated with the trained model. Tail latency under load is tracked as R10.
R5	The budget is not approved, or API costs exceed it.	AB	M / M	Local models; credits bought just in time; documented zero-cost fallback (Section 5.4).	**Monitoring.** All LLM runs so far (the demonstration agent and the LLM benchmark smoke test) used Qwen2.5-7B served locally by Ollama; the scripted benchmark and the latency measurements need no LLM. Paid API calls are needed only for the confirmatory runs. The revised budget is 1,185 SAR.
R6	A team member becomes unavailable and their workstream stalls (single owner per workstream).	AB	M / H	Interfaces fixed in the engineering contract; every change reviewed by a second member; a documentation page per component under `docs/`; report work shared by all.	**Open.** Mitigations are in place; the register is reviewed each sprint.
R7	Vulnerabilities in the gateway or its dependencies turn the security tool into an attack surface.	BY	M / H	Threat model; dedicated security test suite; static analysis (Bandit) and dependency scanning (pip-audit, npm audit) in CI; penetration test (T6.4).	**Occurred – mitigated.** Dependency scans during the build reported vulnerable package versions, which were upgraded before the scans were repeated. Latest results: 0 vulnerable packages of 124 audited by pip-audit, 0 npm audit findings, 0 Bandit issues in 13,023 lines, and 45 security tests passing. Scans are repeated whenever dependencies change.
R8	Development hardware or deployment tooling is not available (no GPU on team laptops; container	MA	M / M	CPU-only detector; 7B local model; native installation script beside Docker; PostgreSQL tested without Docker.	**Occurred – open.** Docker was not available on the machine used for the build, so the Dockerfile and `docker-compose.yml` have not been executed. The system was installed and measured natively with SQLite, and the

ID	Risk	Owner	L / I	Mitigation	Status and what happened
	tooling missing).				PostgreSQL storage path is exercised by integration tests against an embedded PostgreSQL server. NFR5 (deployment with one `docker compose up`) stays unverified until the stack runs on a machine with Docker; the CI workflow contains a Docker build job for this check.

6.3 Risks added during the build

Three risks were identified during the build and added to the register.

Table 13: Risks added during the build

ID	Risk	Owner	L / I	Mitigation	Status
R9	Components built in parallel match their interfaces but disagree in behaviour (integration defects).	BS	M / H	Engineering contract; integration and end-to-end tests; audit replay checks after every benchmark run; an integrator checklist (`docs/dev/INTEGRATOR_TODO.md`).	**Monitoring.** 8 integration tests pass, and 272 of 272 audited decisions in the scripted benchmark replayed to the same action. The checklist items must be closed before the final documents.
R10	Tail latency grows under concurrent load in a single-worker deployment.	BS	M / M	Measure with the client in a separate process; test multiple workers and PostgreSQL before quoting a concurrency figure.	**Open.** With 50 sessions and client and server in one Python process, p95 added latency is 880 ms and p99 1304 ms; with a separate server process p95 is 208 ms.
R11	Code and text produced with an AI assistant contain defects or claims that the team has not checked.	AB	M / H	Disclosed use; every change passes tests, lint, static analysis and review; results quoted only from executions through `reports/results_summary.json`; every reference verified against its source.	**Monitoring.** Deliverables built from the Markdown sources take every measured value from the evidence files. Hand-written figures in the developer pages under `docs/` must be checked against them before release; for example, the latency table in `docs/benchmark.md` predates the latest run.

7 Resource Plan

7.1 People

The team consists of five students; their workstreams and work packages are listed in Table 3. Dr. Omaia Al-Omari supervises the project. The plan schedules a sprint review in each bi-weekly supervisor meeting and asks the supervisor to approve each milestone. The plan involves no external participants; a short questionnaire for security practitioners (Appendix F of the final report) is available if the team decides to validate requirement priorities with practitioners.

7.2 Hardware

Table 14: Hardware resources

Resource	Use	Cost
Team members' personal laptops (no GPU)	Development, tests, local Ollama model (Qwen2.5-7B), benchmark runs	Owned
University lab machines	Fallback for long benchmark runs and for a tunnel-hosted demo	Free
At least one Android phone and one iPhone (iOS 16.4 or later) from team members	Installing the approver PWA and testing Web Push on both platforms	No purchase planned
Cloud VM, 2 vCPU and 4 GB, for six months	Public demonstration gateway with HTTPS	540 SAR (Section 5.3.2)

7.3 Software

Apart from Microsoft Word, which is used for the IS499 document template, the tools in Table 15 are open-source software or free services, and none is charged to the project budget. The adapters require version 2 of the official MCP Python SDK.

Table 15: Software resources

Area	Tools	Used in
Gateway and API	Python 3.12, FastAPI, Uvicorn, Pydantic v2, SQLAlchemy 2.0, MCP Python SDK v2, httpx	T3.1, T4.3, T5.4
Detector	scikit-learn, NumPy, YAML rule files	T4.1, T6.3
Storage	SQLite (development), PostgreSQL 16 (deployment)	T2.3, T3.2
Web	React 18, TypeScript, Vite, Recharts, Node.js	T5.1, T5.2
LLM runtime	Ollama with Qwen2.5-7B	T5.3, T6.2
Quality and security	pytest, Vitest, Ruff, Bandit, pip-audit, npm audit	T6.1, T6.4
Deployment	Docker and Docker Compose, GitHub Actions	T7.1

Area	Tools	Used in
Documentation	Markdown, Mermaid, Matplotlib, python-docx, Microsoft Word	All deliverables

The team also uses an AI coding and writing assistant (Anthropic's Claude), whose use is disclosed in the final report and controlled as described under R11.

7.4 Accounts and external services

Table 16: Accounts and external services

Account or service	Purpose	Holder	Cost
GitHub repository and GitHub Actions	Version control, reviews, CI	Team	Free
GitHub Student Developer Pack (each member)	Student cloud credit, free domain, developer tools [27], [28]	Each member	Free
Anthropic and OpenAI API accounts	Confirmatory benchmark runs	Project manager	Within the 450 SAR LLM line
VM provider (DigitalOcean or AWS Lightsail)	Demonstration gateway	Project manager	Within the 540 SAR VM line
Domain registrar	Project domain for a stable HTTPS origin	Project manager	Within the 45 SAR line
Let's Encrypt	TLS certificates	Deployment owner	Free
Web Push (VAPID key pair)	Approval notifications through browser push services	Generated on the server	Free

Secrets for these accounts are never committed to the repository. The required settings are listed in `.env.example` and are supplied through environment variables at deployment time.

References

[1] K. Schwaber and J. Sutherland, "The 2020 Scrum Guide," Nov. 2020. Accessed: Oct. 11, 2026. [Online]. Available: https://scrumguides.org/scrum-guide.html

[2] Saudi Central Bank (SAMA), "SAMA Affirms Commitment to Exchange Rate Policy," SAMA Media Center, 2020. [Online]. Available: https://www.sama.gov.sa/en-US/MediaCenter/News/Pages/news-557.aspx. Accessed: Oct. 11, 2026.

[3] Ollama, "ollama/ollama," GitHub repository, MIT License. [Online]. Available: https://github.com/ollama/ollama. Accessed: Oct. 11, 2026.

[4] Ollama, "OpenAI compatibility," Ollama Docs. [Online]. Available: https://docs.ollama.com/api/openai-compatibility. Accessed: Oct. 11, 2026.

[5] B. Eidson and J. Simmons, "Web Push for Web Apps on iOS and iPadOS," WebKit Blog, Feb. 16, 2023. [Online]. Available: https://webkit.org/blog/13878/web-push-for-web-apps-on-ios-and-ipados/. Accessed: Oct. 11, 2026.

[6] Anthropic, "Pricing," Claude Platform Docs. [Online]. Available: https://platform.claude.com/docs/en/about-claude/pricing. Accessed: Oct. 11, 2026.

[7] Anthropic, "Models overview," Claude Platform Docs. [Online]. Available: https://platform.claude.com/docs/en/about-claude/models/overview. Accessed: Oct. 11, 2026.

[8] OpenAI, "Pricing," OpenAI API Docs. [Online]. Available: https://developers.openai.com/api/docs/pricing. Accessed: Oct. 11, 2026.

[9] OpenAI, "Models," OpenAI API Docs. [Online]. Available: https://developers.openai.com/api/docs/models. Accessed: Oct. 11, 2026.

[10] Anthropic, "How do I pay for my Claude API usage?," Claude Help Center. [Online]. Available: https://support.claude.com/en/articles/8977456. Accessed: Oct. 11, 2026.

[11] DigitalOcean, "Droplet Pricing." [Online]. Available: https://www.digitalocean.com/pricing/droplets. Accessed: Oct. 11, 2026.

[12] Amazon Web Services, "Amazon Lightsail Pricing." [Online]. Available: https://aws.amazon.com/lightsail/pricing/. Accessed: Oct. 11, 2026.

[13] Hetzner Online GmbH, "Hetzner Price Adjustment 15 June 2026," Hetzner Docs, ID GE-D9256, Jun. 15, 2026. [Online]. Available: https://docs.hetzner.com/general/infrastructure-and-availability/price-adjustment/. Accessed: Oct. 11, 2026.

[14] Hetzner Online GmbH, "IP pricing," Hetzner Docs. [Online]. Available: https://docs.hetzner.com/general/infrastructure-and-availability/ipv4-pricing/. Accessed: Oct. 11, 2026.

[15] Hetzner Online GmbH, "Cheap cloud-hosting – low vps prices for developers" and "Hetzner Virtual Private Server: Best Price-Performance Ratio." [Online]. Available: https://www.hetzner.com/cloud/cost-optimized/ and https://www.hetzner.com/cloud/regular-performance/. Accessed: Oct. 11, 2026.

[16] Google, "Get started with Play Console," Play Console Help. [Online]. Available: https://support.google.com/googleplay/android-developer/answer/6112435. Accessed: Oct. 11, 2026.

[17] Google, "App testing requirements for new personal developer accounts," Play Console Help. [Online]. Available: https://support.google.com/googleplay/android-developer/answer/14151465. Accessed: Oct. 11, 2026.

[18] Apple Inc., "Become a member - Apple Developer Program," Apple Developer. [Online]. Available: https://developer.apple.com/programs/enroll/. Accessed: Oct. 11, 2026.

[19] Porkbun, "Domain Name Pricing." [Online]. Available: https://porkbun.com/products/domains. Accessed: Oct. 11, 2026.

[20] Internet Security Research Group, "About Let's Encrypt," Let's Encrypt. [Online]. Available: https://letsencrypt.org/about/. Accessed: Oct. 11, 2026.

[21] MDN contributors, "Service Worker API," MDN Web Docs, Mozilla. [Online]. Available: https://developer.mozilla.org/en-US/docs/Web/API/Service_Worker_API. Accessed: Oct. 11, 2026.

[22] M. McPherrin, "Decreasing Certificate Lifetimes to 45 Days," Let's Encrypt, Dec. 2, 2025. [Online]. Available: https://letsencrypt.org/2025/12/02/from-90-to-45. Accessed: Oct. 11, 2026.

[23] Sahara Net, "Domain Pricing." [Online]. Available: https://shop.sahara.com/index.php?rp=/domain/pricing. Accessed: Oct. 11, 2026.

[24] SaudiNIC, "Registrars." [Online]. Available: https://nic.sa/en/registrars. Accessed: Oct. 11, 2026.

[25] Communications, Space & Technology Commission (SaudiNIC), "Saudi Domain Names Registration Regulations." [Online]. Available: https://nic.sa/en/help/regulation. Accessed: Oct. 11, 2026.

[26] Google, "Gemini Developer API pricing," Google AI for Developers. [Online]. Available: https://ai.google.dev/gemini-api/docs/pricing. Accessed: Oct. 11, 2026.

[27] GitHub, "GitHub Student Developer Pack," GitHub Education. [Online]. Available: https://education.github.com/pack. Accessed: Oct. 11, 2026.

[28] GitHub, "Apply to GitHub Education as a student," GitHub Docs. [Online]. Available: https://docs.github.com/en/education/about-github-education/github-education-for-students/apply-to-github-education-as-a-student. Accessed: Oct. 11, 2026.

[29] Oracle, "Always Free Resources," Oracle Cloud Infrastructure Documentation. [Online]. Available: https://docs.oracle.com/en-us/iaas/Content/FreeTier/freetier_topic-Always_Free_Resources.htm. Accessed: Oct. 11, 2026.

[30] Cloudflare, "Cloudflare Tunnel," Cloudflare Docs. [Online]. Available: https://developers.cloudflare.com/tunnel/. Accessed: Oct. 11, 2026.

[31] M. McPherrin, "6-day and IP Address Certificates are Generally Available," Let's Encrypt, Jan. 15, 2026. [Online]. Available: https://letsencrypt.org/2026/01/15/6day-and-ip-general-availability. Accessed: Oct. 11, 2026.

[32] Cloudflare, "Quick Tunnels," Cloudflare Docs. [Online]. Available: https://developers.cloudflare.com/cloudflare-one/connections/connect-networks/do-more-with-tunnels/trycloudflare/. Accessed: Oct. 11, 2026.